

Username enumeration via different responses

Topic: Authentication | Difficulty: Apprentice

Description

The login form returns distinct error messages for invalid usernames versus valid usernames with incorrect passwords. This behavioral difference allows an attacker to enumerate valid usernames via automated requests and then target those accounts with password brute-force.

Steps to Exploit

1. Navigate to the login page.
2. Enter a random invalid username and any password.
3. Observe the error message: 'Invalid username'.
4. Enter a known valid username and an incorrect password.
5. Observe the different error message: 'Incorrect password'.
6. Use Burp Intruder to iterate a username wordlist; filter for 'Incorrect password' responses.
7. For each valid username found run a password brute-force attack.

Proof of Concept

Invalid username response:

```
Invalid username
```

Valid username response:

```
Incorrect password
```

Burp Intruder payload:

```
POST /login
username=[FUZZ]&password=password
```

Impact

- Enumeration of valid user accounts for targeted attacks.
- Reduction of brute-force attack search space.
- Potential account takeover when combined with password spraying.
- Privacy breach by confirming account existence.

Mitigation / Remediation

1. Return a generic error message for all failed login attempts ('Invalid credentials').
2. Implement account lockout or progressive delays on repeated failed attempts.
3. Normalize response times to prevent timing-based enumeration.
4. Implement CAPTCHA after a threshold of failed attempts.

CVSS Score

CVSS v3.1: 5.3 (Medium)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CVSS Justification

- Attack Vector: Network - automated HTTP requests.
- Attack Complexity: Low - simple wordlist iteration.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality: Low - valid usernames disclosed.
- Integrity / Availability: None.